ONE-PAGE BRIEF

Post-quantum cryptography review: lido-core @ 2bd532298d85

Client: Lido — public repository (passive review) · Source: github.com/lidofinance/core, commit `2bd532298d85` · Reviewed: 2026-11-06 13:25 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 0 of 4
no post-quantum cryptography

FINDINGS
5 Critical **26** High **28** Medium
12 Low **7** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Critical QSI-2026-18228	**@openzeppelin/contracts 3.4.0 is affected by GHSA-fg47-3c2x-m2wr (CVE-2021-39167)** What to do: Upgrade to a fixed version (3.4.2, 4.3.1).
Critical QSI-2026-18234	**babel-traverse 6.26.0 is affected by GHSA-67hx-6x53-jw92 (CVE-2023-45133)** What to do: Upgrade to a fixed version (none published yet; see the advisory for mitigations).
Critical QSI-2026-18252	**crypto-js 3.3.0 is affected by GHSA-rg76-677x-56q9 (CVE-2026-71851)** What to do: Upgrade to a fixed version (4.0.0).
Critical QSI-2026-18253	**crypto-js 3.3.0 is affected by GHSA-xwcq-pm8m-c4vf (CVE-2023-46233)** What to do: Upgrade to a fixed version (4.2.0).

67 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium transaction and message signing	ECDSA	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum…
Medium role not determined	BLS12-381, ECDSA	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)…

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 47; each needs checking against the code.

Static review of source code and manifests; files analysed: 267. No requests were sent to the owner's systems.

Full report, content SHA-256: `7acb06161ac73d5b7816c3afbf84d682884423d2d6c60d69a9dc8ea6f6ce7e73`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.